

Security+ 1.2 · Gap Analysis

Mestre CyberSec — PDF baseado na aula do Professor Messer · 1.2 — Gap Analysis (6:44) · [vídeo original ↗](#)
· [YouTube ↗](#)

Análise de lacuna: compara o estado atual (o que tens) vs o desejado (NIST CSF, ISO 27001). A GAP = o que falta. Alimenta o roteiro de melhoria.

Highlights que a prova cobra

- Gap analysis alimenta o risk register
- É a PRIMEIRA etapa de implementação de framework

Dicas de prova

- A prova: 'organization checks its security posture against NIST CSF' = gap analysis

Cenário clássico: Cenário típico: 'empresa compara seu estado atual com o NIST CSF pra descobrir o que falta' → gap analysis.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. A nova liderança de segurança de uma fintech deseja entender o nível de maturidade da empresa em relação ao NIST Cybersecurity Framework (CSF) para definir o orçamento de cibersegurança do próximo ano. Qual é a avaliação formal indicada para mapear a situação atual versus os requisitos do framework?", o: ["Gap Analysis (Análise de Lacunas)", "Scan de portas com Nmap", "Teste de intrusão do tipo Red Team", "Auditoria de desempenho de rede"], c: 0, e: "A Gap Analysis compara o estado atual da postura de segurança da organização com um padrão, regulamentação ou framework de referência desejado, identificando as lacunas (gaps) que precisam ser preenchidas."}, {id: "gap2", t: "secplus", d: "d5", q: "Qual é a principal saída (entregável) produzida ao término de um processo de Gap Analysis?", o: ["Um plano de ação e remediação priorizado para alcançar a conformidade", "A demissão dos funcionários que cometeram erros operacionais", "A compra imediata de ferramentas caras sem estudo prévio", "Um certificado de imunidade a ataques cibernéticos"], c: 0, e: "O entregável central da Gap Analysis é um relatório de discrepâncias acompanhado de um plano de ação (roadmap de remediação) priorizado por criticidade e risco para fechar as brechas encontradas."}, {id: "gap3", t: "secplus", d: "d5", q: "Uma empresa que processa pagamentos com cartão de crédito precisa se adequar ao PCI DSS v4.0. Ao realizar a Gap Analysis, a equipe constata que senhas de contas de serviço não são rotacionadas automaticamente. Esse achado representa:", o: ["Um 'gap' (lacuna de controle) de conformidade que deve ser remediado", "Um controle compensatório aprovado", "Um falso positivo irrelevante para a auditoria", "Uma violação que dispensa qualquer ação se o firewall estiver ativo"], c: 0, e: "Qualquer divergência entre a exigência mandatória do framework (PCI DSS) e a prática operacional real da empresa constitui uma lacuna de controle (gap)."}, {id: "gap4", t: "secplus", d: "d5", q: "Qual é a diferença primordial entre uma Avaliação de Vulnerabilidades (Vulnerability Assessment) e uma Análise de Lacunas (Gap Analysis)?", o: ["A análise de vulnerabilidades busca falhas técnicas em sistemas (softwares/portas); a Gap Analysis compara processos e políticas a normas e padrões de segurança", "A Gap Analysis só analisa código-fonte; a análise de vulnerabilidades só analisa contratos", "Ambas são idênticas e rodam as mesmas ferramentas de varredura", "A Gap Analysis é feita exclusivamente por invasores externos"], c: 0, e: "Vulnerability Assessment é técnica e automatizada (procura bugs e patches faltantes). Gap Analysis é estratégica e holística (compara pessoas, processos, governança e controles técnicos contra um padrão formal)."}, {id: "gap5", t: "secplus", d: "d5", q: "Ao conduzir uma Gap Analysis contra o framework ISO/IEC 27001, qual é o papel da Declaração de Aplicabilidade (Statement of Applicability - SoA)?", o: ["Documentar quais controles do Anexo A são aplicáveis à empresa e justificar a exclusão dos demais", "Listar todos os endereços IP dos servidores da empresa", "Descrever o algoritmo de criptografia do banco de dados", "Registrar o contrato de trabalho dos administradores"], c: 0, e: "O SoA na ISO 27001 documenta formalmente quais controles de segurança são necessários para o contexto da organização e a justificativa para qualquer controle não adotado."}, {id: "gap6", t: "secplus", d: "d5", q: "Durante uma Gap Analysis, a equipe de segurança descobre

que uma política exige autenticação de dois fatores para todos os funcionários, mas o departamento comercial usa apenas usuário e senha há mais de um ano. Isso evidencia uma lacuna de:", o:["Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática)", "Falta de documentação gerencial", "Falha de hardware no servidor de banco de dados", "Incompatibilidade com leis trabalhistas"],c:0, e:"Uma das maiores causas de gap é a discrepância entre a política escrita (managerial) e a execução real pelos usuários (operational/technical).", {id:"gap7",t:"secplus",d:"d5",q:"Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser prioritariamente executada?", o:["Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções", "Apenas após um ataque cibernético de grandes proporções", "No encerramento definitivo das operações da empresa", "Exclusivamente antes de contratar estagiários"],c:0, e:"A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar."}, {id:"gap8",t:"secplus",d:"d5",q:"Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?", o:["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"],c:0, e:"Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado)."}, {id:"gap9",t:"secplus",d:"d5",q:"Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o:["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"],c:0, e:"A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o:["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"],c:0, e:"A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o:["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"],c:0, e:"Zero Trust parte do pressuposto de que ameaças já existem

dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso.", {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o:["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"],c:0, e:"O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"],c:0, e:"A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas."}, {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois."}, {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso

necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA).", {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical", "Detective · Technical", "Preventive · Managerial", "Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o:["Preventive", "Detective", "Deterrent", "Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective", "Corrective", "Preventive", "Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do

sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective","Detective","Compensating","Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."}, {id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial)."}, {id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective","Corrective — na categoria managerial (processo, documentação)","Preventive","Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial)."}, {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical","Detective + Physical","Preventive + Physical","Deterrent + Technical"],c:1, e:"Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective)."}, {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches)."}, // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante

intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade", "Confidencialidade", "Disponibilidade", "Não-repúdio"], c: 1, e: "Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação.", {id: "cia2", t: "secplus", d: "d1", q: "Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Autenticação"], c: 1, e: "Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável."}, {id: "cia3", t: "secplus", d: "d1", q: "Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Autenticidade"], c: 2, e: "Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema.", {id: "cia4", t: "secplus", d: "d3", q: "O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o: ["Oferece integridade; NÃO dá confidencialidade (não cifra)", "Oferece confidencialidade; NÃO dá integridade", "Oferece disponibilidade; NÃO dá integridade", "Oferece as 3 ao mesmo tempo"], c: 0, e: "Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."}, {id: "cia5", t: "secplus", d: "d3", q: "Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o: ["Hash SHA-256 puro", "Criptografia AES simétrica", "Assinatura digital com chave privada", "Backup offline em fita"], c: 2, e: "A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."}, {id: "cia6", t: "secplus", d: "d3", q: "Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o: ["At rest — criptografia de disco BitLocker", "In transit — túnel TLS / VPN IPsec", "In use — enclaves seguros de CPU", "Rest / transit / use — todas indistintas"], c: 1, e: "Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id: "cia7", t: "secplus", d: "d3", q: "Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o: ["Criptografia AES", "Não-repúdio (non-repudiation) via assinatura digital", "Cluster de alta disponibilidade", "Hash MD5 da mensagem"], c: 1, e: "Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id: "cia8", t: "secplus", d: "d3", q: "Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o: ["Disponibilidade — agiliza o backup", "Integridade — garante que o arquivo não corrompa", "Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras", "Autenticação — prova a identidade do usuário"], c: 2, e: "Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for

roubada."}, {id:"cia9",t:"secplus",d:"d1",q:"CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:1, e:"Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."}, {id:"cia10",t:"secplus",d:"d2",q:"CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:2, e:"Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id:"s101",t:"secplus",d:"d1",q:"Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o:["BEC / CEO fraud (fraude do CEO)","Whaling","Vishing","Tailgating"],c:0, e:"BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id:"s102",t:"secplus",d:"d1",q:"Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o:["Spyware","Ransomware","Rootkit","Worm"],c:1, e:"Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."}, {id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o:["CVE pública","Zero-day","Backdoor","Falso positivo"],c:1, e:"Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura ===== {id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo

dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de

resposta a incidente, o que vem PRIMEIRO?", o:

["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas.

Preparar (plano, ferramentas, treino) vem antes de tudo."},

{id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."},

{id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC =====

{id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."},

{id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:

resposta a incidente, o que vem PRIMEIRO?", o:

["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vaziar dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorque também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o:["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o

relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

2. Qual é a principal saída (entregável) produzida ao término de um processo de Gap Analysis?", o:["Um plano de ação e remediação priorizado para alcançar a conformidade", "A demissão dos funcionários que cometeram erros operacionais", "A compra imediata de ferramentas caras sem estudo prévio", "Um certificado de imunidade a ataques cibernéticos"],c:0, e:"O entregável central da Gap Analysis é um relatório de discrepâncias acompanhado de um plano de ação (roadmap de remediação) priorizado por criticidade e risco para fechar as brechas encontradas.", {id:"gap3",t:"secplus",d:"d5",q:"Uma empresa que processa pagamentos com cartão de crédito precisa se adequar ao PCI DSS v4.0. Ao realizar a Gap Analysis, a equipe constata que senhas de contas de serviço não são rotacionadas automaticamente. Esse achado representa:", o:["Um 'gap' (lacuna de controle) de conformidade que deve ser remediado", "Um controle compensatório aprovado", "Um falso positivo irrelevante para a auditoria", "Uma violação que dispensa qualquer ação se o firewall estiver ativo"],c:0, e:"Qualquer divergência entre a exigência mandatória do framework (PCI DSS) e a prática operacional real da empresa constitui uma lacuna de controle (gap)."}, {id:"gap4",t:"secplus",d:"d5",q:"Qual é a diferença primordial entre uma Avaliação de Vulnerabilidades (Vulnerability Assessment) e uma Análise de Lacunas (Gap Analysis)?", o:["A análise de vulnerabilidades busca falhas técnicas em sistemas (softwares/portas); a Gap Analysis compara processos e políticas a normas e padrões de segurança", "A Gap Analysis só analisa código-fonte; a análise de vulnerabilidades só analisa contratos", "Ambas são idênticas e rodam as mesmas ferramentas de varredura", "A Gap Analysis é feita exclusivamente por invasores externos"],c:0, e:"Vulnerability Assessment é técnica e automatizada (procura bugs e patches faltantes). Gap Analysis é estratégica e holística (compara pessoas, processos, governança e controles técnicos contra um padrão formal)."}, {id:"gap5",t:"secplus",d:"d5",q:"Ao conduzir uma Gap Analysis contra o framework ISO/IEC 27001, qual é o papel da Declaração de Aplicabilidade (Statement of Applicability - SoA)?", o:["Documentar quais controles do Anexo A são aplicáveis à empresa e justificar a exclusão dos demais", "Listar todos os endereços IP dos servidores da empresa", "Descrever o algoritmo de criptografia do banco de dados", "Registrar o contrato de trabalho dos administradores"],c:0, e:"O SoA na ISO 27001 documenta formalmente quais controles de segurança são necessários para o contexto da organização e a justificativa para qualquer controle não adotado.", {id:"gap6",t:"secplus",d:"d5",q:"Durante uma Gap Analysis, a equipe de segurança descobre que uma política exige autenticação de dois fatores para todos os funcionários, mas o departamento comercial usa apenas usuário e senha há mais de um ano. Isso evidencia uma lacuna de:", o:["Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática)", "Falta de documentação gerencial", "Falha de hardware no servidor de banco de dados", "Incompatibilidade com leis trabalhistas"],c:0, e:"Uma das maiores causas de gap é a discrepância entre a política escrita (managerial) e a execução real pelos usuários (operational/technical)."}, {id:"gap7",t:"secplus",d:"d5",q:"Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser

prioritariamente executada?", o:["Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções", "Apenas após um ataque cibernético de grandes proporções", "No encerramento definitivo das operações da empresa", "Exclusivamente antes de contratar estagiários"],c:0, e:"A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar."}, {id:"gap8",t:"secplus",d:"d5",q:"Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?", o:["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"],c:0, e:"Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado)."}, {id:"gap9",t:"secplus",d:"d5",q:"Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o:["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"],c:0, e:"A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o:["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"],c:0, e:"A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o:["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"],c:0, e:"Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso."}, {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o:["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"],c:0, e:"O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."},

{id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"],c:0, e:"A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas."}, {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois."}, {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero

Trust Network Access)), "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical", "Detective · Technical", "Preventive · Managerial", "Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o: ["Preventive", "Detective", "Deterrent", "Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective", "Corrective", "Preventive", "Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective", "Detective", "Compensating", "Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre

precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."}, {id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial)."}, {id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective","Corrective — na categoria managerial (processo, documentação)","Preventive","Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial)."}, {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical","Detective + Physical","Preventive + Physical","Deterrent + Technical"],c:1, e:"Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective)."}, {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches)."}, // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade","Confidencialidade","Disponibilidade","Não-repúdio"],c:1, e:"Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação."}, {id:"cia2",t:"secplus",d:"d1",q:"Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticação"],c:1, e:"Integridade: o

dado foi adulterado no trajeto, deixando de ser exato e confiável."},
{id:"cia3",t:"secplus",d:"d1",q:"Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticidade"],c:2, e:"Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema."}, {id:"cia4",t:"secplus",d:"d3",q:"O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o:["Oferece integridade; NÃO dá confidencialidade (não cifra)","Oferece confidencialidade; NÃO dá integridade","Oferece disponibilidade; NÃO dá integridade","Oferece as 3 ao mesmo tempo"],c:0, e:"Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."},
{id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."},
{id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-repúdio (non-repudiation) via assinatura digital","Cluster de alta disponibilidade","Hash MD5 da mensagem"],c:1, e:"Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."},
{id:"cia8",t:"secplus",d:"d3",q:"Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o:["Disponibilidade — agiliza o backup","Integridade — garante que o arquivo não corrompa","Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras","Autenticação — prova a identidade do usuário"],c:2, e:"Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id:"cia9",t:"secplus",d:"d1",q:"CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:1, e:"Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."},
{id:"cia10",t:"secplus",d:"d2",q:"CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação

multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:2, e:"Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id:"s101",t:"secplus",d:"d1",q:"Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o:["BEC / CEO fraud (fraude do CEO)","Whaling","Vishing","Tailgating"],c:0, e:"BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id:"s102",t:"secplus",d:"d1",q:"Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o:["Spyware","Ransomware","Rootkit","Worm"],c:1, e:"Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."}, {id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o:["CVE pública","Zero-day","Backdoor","Falso positivo"],c:1, e:"Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura ===== {id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email)

protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o:["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando

evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."},

{id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC =====

{id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."},

{id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os

dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o: ["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão).", {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vazamento de dados + chantagem os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorquer também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o: ["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Governar — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção

de dados", "Uma ferramenta de varredura"], c:0, e: "Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id: "s121", t: "secplus", d: "d3", q: "Diferença entre IDS e IPS:", o: ["IDS detecta e alerta; IPS detecta e BLOQUEIA", "São a mesma coisa", "IDS é de disco; IPS é de rede", "IPS só grava log"], c:0, e: "IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id: "s122", t: "secplus", d: "d3", q: "O que a PKI (infraestrutura de chave pública) sustenta na prática?", o: ["Certificados digitais (o cadeado do HTTPS)", "O antivírus", "O backup em nuvem", "A senha do Wi-Fi"], c:0, e: "PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id: "s123", t: "secplus", d: "d3", q: "SAST e DAST testam segurança de software. A diferença:", o: ["SAST lê o código PARADO; DAST testa a app RODANDO", "SAST é pago; DAST é grátis", "São sinônimos", "SAST é de rede; DAST é de disco"], c:0, e: "SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id: "s124", t: "secplus", d: "d5", q: "ISO/IEC 27001 é:", o: ["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)", "Uma lei dos EUA", "Um tipo de firewall", "Um scanner de vulnerabilidade"], c:0, e: "ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id: "s125", t: "secplus", d: "d5", q: "TPRM (Third-Party Risk Management) trata de:", o: ["Avaliar o risco de segurança dos FORNECEDORES/terceiros", "Testar a própria rede", "Treinar funcionários", "Criptografar backup"], c:0, e: "TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id: "s130", t: "secplus", d: "d1", q: "Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

3. Uma empresa que processa pagamentos com cartão de crédito precisa se adequar ao PCI DSS v4.0. Ao realizar a Gap Analysis, a equipe constata que senhas de contas de serviço não são rotacionadas automaticamente. Esse achado representa:", o:["Um 'gap' (lacuna de controle) de conformidade que deve ser remediado", "Um controle compensatório aprovado", "Um falso positivo irrelevante para a auditoria", "Uma violação que dispensa qualquer ação se o firewall estiver ativo"],c:0, e:"Qualquer divergência entre a exigência mandatória do framework (PCI DSS) e a prática operacional real da empresa constitui uma lacuna de controle (gap)."}, {id:"gap4",t:"secplus",d:"d5",q:"Qual é a diferença primordial entre uma Avaliação de Vulnerabilidades (Vulnerability Assessment) e uma Análise de Lacunas (Gap Analysis)?", o:["A análise de vulnerabilidades busca falhas técnicas em sistemas (softwares/portas); a Gap Analysis compara processos e políticas a normas e padrões de segurança", "A Gap Analysis só analisa código-fonte; a análise de vulnerabilidades só analisa contratos", "Ambas são idênticas e rodam as mesmas ferramentas de varredura", "A Gap Analysis é feita exclusivamente por invasores externos"],c:0, e:"Vulnerability Assessment é técnica e automatizada (procura bugs e patches faltantes). Gap Analysis é estratégica e holística (compara pessoas, processos, governança e controles técnicos contra um padrão formal)."}, {id:"gap5",t:"secplus",d:"d5",q:"Ao conduzir uma Gap Analysis contra o framework ISO/IEC 27001, qual é o papel da Declaração de Aplicabilidade (Statement of Applicability - SoA)?", o:["Documentar quais controles do Anexo A são aplicáveis à empresa e justificar a exclusão dos demais", "Listar todos os endereços IP dos servidores da empresa", "Descrever o algoritmo de criptografia do banco de dados", "Registrar o contrato de trabalho dos administradores"],c:0, e:"O SoA na ISO 27001 documenta formalmente quais controles de segurança são necessários para o contexto da organização e a justificativa para qualquer controle não adotado."}, {id:"gap6",t:"secplus",d:"d5",q:"Durante uma Gap Analysis, a equipe de segurança descobre que uma política exige autenticação de dois fatores para todos os funcionários, mas o departamento comercial usa apenas usuário e senha há mais de um ano. Isso evidencia uma lacuna de:", o:["Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática)", "Falta de documentação gerencial", "Falha de hardware no servidor de banco de dados", "Incompatibilidade com leis trabalhistas"],c:0, e:"Uma das maiores causas de gap é a discrepância entre a política escrita (managerial) e a execução real pelos usuários (operational/technical)."}, {id:"gap7",t:"secplus",d:"d5",q:"Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser prioritariamente executada?", o:["Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções", "Apenas após um ataque cibernético de grandes proporções", "No encerramento definitivo das operações da empresa", "Exclusivamente antes de contratar estagiários"],c:0, e:"A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar."}, {id:"gap8",t:"secplus",d:"d5",q:"Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de

segurança da organização?", o: ["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"], c: 0, e: "Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado).", {id: "gap9", t: "secplus", d: "d5", q: "Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o: ["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"], c: 0, e: "A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance).", {id: "gap10", t: "secplus", d: "d5", q: "Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o: ["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"], c: 0, e: "A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora.", {id: "zt1", t: "secplus", d: "d2", q: "O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o: ["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"], c: 0, e: "Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso.", {id: "zt2", t: "secplus", d: "d2", q: "Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o: ["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"], c: 0, e: "O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo).", {id: "zt3", t: "secplus", d: "d2", q: "Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o: ["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"], c: 0, e: "A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-

rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas."}, {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois."}, {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa

checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical","Detective · Technical","Preventive · Managerial","Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o: ["Preventive","Detective","Deterrent","Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective","Corrective","Preventive","Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective","Detective","Compensating","Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."}, {id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este

controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective).", {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial).", {id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective","Corrective — na categoria managerial (processo, documentação)","Preventive","Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial).", {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical","Detective + Physical","Preventive + Physical","Deterrent + Technical"],c:1, e:"Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective).", {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches).", // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade","Confidencialidade","Disponibilidade","Não-repúdio"],c:1, e:"Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação.", {id:"cia2",t:"secplus",d:"d1",q:"Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticação"],c:1, e:"Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável.", {id:"cia3",t:"secplus",d:"d1",q:"Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticidade"],c:2, e:"Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema.", {id:"cia4",t:"secplus",d:"d3",q:"O que uma função HASH criptográfica (como

SHA-256) oferece e o que ela NÃO oferece?", o:["Oferece integridade; NÃO dá confidencialidade (não cifra)","Oferece confidencialidade; NÃO dá integridade","Oferece disponibilidade; NÃO dá integridade","Oferece as 3 ao mesmo tempo"],c:0, e:"Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."}, {id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."}, {id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-repúdio (non-repudiation) via assinatura digital","Cluster de alta disponibilidade","Hash MD5 da mensagem"],c:1, e:"Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id:"cia8",t:"secplus",d:"d3",q:"Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o:["Disponibilidade — agiliza o backup","Integridade — garante que o arquivo não corrompa","Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras","Autenticação — prova a identidade do usuário"],c:2, e:"Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id:"cia9",t:"secplus",d:"d1",q:"CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:1, e:"Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."}, {id:"cia10",t:"secplus",d:"d2",q:"CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:2, e:"Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id:"s101",t:"secplus",d:"d1",q:"Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o:["BEC / CEO fraud (fraude do CEO)","Whaling","Vishing","Tailgating"],c:0,

e:"BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta.",
{id:"s102",t:"secplus",d:"d1",q:"Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o:["Spyware","Ransomware","Rootkit","Worm"],c:1, e:"Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."},
{id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o:["CVE pública","Zero-day","Backdoor","Falso positivo"],c:1, e:"Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."},
{id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."},
{id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura =====
{id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."},
{id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust

(modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // =====
SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:
["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."},
{id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."},
{id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."},
{id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o:
["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."},
{id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."},
{id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o

que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC =====

{id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."},

{id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vaziar dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados.

Camada 3: extorque também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais.", {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o:["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que

a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

4. Qual é a diferença primordial entre uma Avaliação de Vulnerabilidades (Vulnerability Assessment) e uma Análise de Lacunas (Gap Analysis)?", o: ["A análise de vulnerabilidades busca falhas técnicas em sistemas (softwares/portas); a Gap Analysis compara processos e políticas a normas e padrões de segurança", "A Gap Analysis só analisa código-fonte; a análise de vulnerabilidades só analisa contratos", "Ambas são idênticas e rodam as mesmas ferramentas de varredura", "A Gap Analysis é feita exclusivamente por invasores externos"], c: 0, e: "Vulnerability Assessment é técnica e automatizada (procura bugs e patches faltantes). Gap Analysis é estratégica e holística (compara pessoas, processos, governança e controles técnicos contra um padrão formal).", {id: "gap5", t: "secplus", d: "d5", q: "Ao conduzir uma Gap Analysis contra o framework ISO/IEC 27001, qual é o papel da Declaração de Aplicabilidade (Statement of Applicability - SoA)?", o: ["Documentar quais controles do Anexo A são aplicáveis à empresa e justificar a exclusão dos demais", "Listar todos os endereços IP dos servidores da empresa", "Descrever o algoritmo de criptografia do banco de dados", "Registrar o contrato de trabalho dos administradores"], c: 0, e: "O SoA na ISO 27001 documenta formalmente quais controles de segurança são necessários para o contexto da organização e a justificativa para qualquer controle não adotado."}, {id: "gap6", t: "secplus", d: "d5", q: "Durante uma Gap Analysis, a equipe de segurança descobre que uma política exige autenticação de dois fatores para todos os funcionários, mas o departamento comercial usa apenas usuário e senha há mais de um ano. Isso evidencia uma lacuna de:", o: ["Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática)", "Falta de documentação gerencial", "Falha de hardware no servidor de banco de dados", "Incompatibilidade com leis trabalhistas"], c: 0, e: "Uma das maiores causas de gap é a discrepância entre a política escrita (managerial) e a execução real pelos usuários (operational/technical)."}, {id: "gap7", t: "secplus", d: "d5", q: "Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser prioritariamente executada?", o: ["Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções", "Apenas após um ataque cibernético de grandes proporções", "No encerramento definitivo das operações da empresa", "Exclusivamente antes de contratar estagiários"], c: 0, e: "A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar."}, {id: "gap8", t: "secplus", d: "d5", q: "Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?", o: ["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"], c: 0, e: "Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado)."}, {id: "gap9", t: "secplus", d: "d5", q: "Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o: ["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas

as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"],c:0, e:"A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o:["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"],c:0, e:"A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o:["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"],c:0, e:"Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso."}, {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o:["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"],c:0, e:"O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"],c:0, e:"A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física)

para barrar invasores com senhas roubadas."}, {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois."}, {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints,

redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical","Detective · Technical","Preventive · Managerial","Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o: ["Preventive","Detective","Deterrent","Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective","Corrective","Preventive","Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective","Detective","Compensating","Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."}, {id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo

administrativo e diretriz organizacional (Managerial)."},

{id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective","Corrective — na categoria managerial (processo, documentação)","Preventive","Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial)."}, {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical","Detective + Physical","Preventive + Physical","Deterrent + Technical"],c:1, e:"Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective)."}, {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches)."}, // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade","Confidencialidade","Disponibilidade","Não-repúdio"],c:1, e:"Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação."}, {id:"cia2",t:"secplus",d:"d1",q:"Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticação"],c:1, e:"Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável."}, {id:"cia3",t:"secplus",d:"d1",q:"Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticidade"],c:2, e:"Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema."}, {id:"cia4",t:"secplus",d:"d3",q:"O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o:["Oferece integridade; NÃO dá confidencialidade (não cifra)","Oferece confidencialidade; NÃO dá integridade","Oferece disponibilidade; NÃO dá integridade","Oferece as 3 ao mesmo tempo"],c:0, e:"Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."}, {id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup

offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."}, {id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-repúdio (non-repudiation) via assinatura digital","Cluster de alta disponibilidade","Hash MD5 da mensagem"],c:1, e:"Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id:"cia8",t:"secplus",d:"d3",q:"Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o:["Disponibilidade — agiliza o backup","Integridade — garante que o arquivo não corrompa","Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras","Autenticação — prova a identidade do usuário"],c:2, e:"Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id:"cia9",t:"secplus",d:"d1",q:"CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:1, e:"Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."}, {id:"cia10",t:"secplus",d:"d2",q:"CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:2, e:"Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id:"s101",t:"secplus",d:"d1",q:"Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o:["BEC / CEO fraud (fraude do CEO)","Whaling","Vishing","Tailgating"],c:0, e:"BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id:"s102",t:"secplus",d:"d1",q:"Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o:["Spyware","Ransomware","Rootkit","Worm"],c:1, e:"Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."},

{id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o:["CVE pública","Zero-day","Backdoor","Falso positivo"],c:1, e:"Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura ===== {id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume.

Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o:["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."}, {id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."}, {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da

vulnerabilidade", "O SLA do fornecedor"], c:1, e: "RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno.", {id:"s503", t:"secplus", d:"d5", q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco", "Evitar o risco", "Transferir o risco", "Mitigar o risco"], c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107", t:"secplus", d:"d1", q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer", "Adware", "Keylogger de hardware", "Rootkit de firmware"], c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108", t:"secplus", d:"d1", q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado", "Phishing + VPN sem MFA / credencial vazada", "Cabo de rede exposto", "Falta de antivírus"], c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109", t:"secplus", d:"d1", q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark", "Mimikatz", "Nmap", "Nessus"], c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110", t:"secplus", d:"d1", q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)", "Negação de serviço", "Engenharia social", "Sniffing"], c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111", t:"secplus", d:"d4", q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração", "Contenção", "Sanitização", "Ofuscação"], c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112", t:"secplus", d:"d1", q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes", "Criptografar + ameaçar vaziar dados + chantagear os clientes da vítima", "Pedir resgate 3 vezes", "Atacar 3 empresas juntas"], c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorque também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113", t:"secplus", d:"d1", q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10", "MITRE ATT&CK", "ISO 27001", "PCI-DSS"], c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114", t:"secplus", d:"d4", q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o:["SIEM", "SOAR", "EDR", "VPN"], c:1, e:"SOAR (Orchestration, Automation & Response) roda

playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta.", {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como

um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

5. Ao conduzir uma Gap Analysis contra o framework ISO/IEC 27001, qual é o papel da Declaração de Aplicabilidade (Statement of Applicability - SoA)?", o:["Documentar quais controles do Anexo A são aplicáveis à empresa e justificar a exclusão dos demais", "Listar todos os endereços IP dos servidores da empresa", "Descrever o algoritmo de criptografia do banco de dados", "Registrar o contrato de trabalho dos administradores"],c:0, e:"O SoA na ISO 27001 documenta formalmente quais controles de segurança são necessários para o contexto da organização e a justificativa para qualquer controle não adotado."}, {id:"gap6",t:"secplus",d:"d5",q:"Durante uma Gap Analysis, a equipe de segurança descobre que uma política exige autenticação de dois fatores para todos os funcionários, mas o departamento comercial usa apenas usuário e senha há mais de um ano. Isso evidencia uma lacuna de:", o:["Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática)", "Falta de documentação gerencial", "Falha de hardware no servidor de banco de dados", "Incompatibilidade com leis trabalhistas"],c:0, e:"Uma das maiores causas de gap é a discrepância entre a política escrita (managerial) e a execução real pelos usuários (operational/technical)."}, {id:"gap7",t:"secplus",d:"d5",q:"Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser prioritariamente executada?", o:["Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções", "Apenas após um ataque cibernético de grandes proporções", "No encerramento definitivo das operações da empresa", "Exclusivamente antes de contratar estagiários"],c:0, e:"A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar."}, {id:"gap8",t:"secplus",d:"d5",q:"Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?", o:["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"],c:0, e:"Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado)."}, {id:"gap9",t:"secplus",d:"d5",q:"Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o:["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"],c:0, e:"A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o:["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o

histórico de e-mails da empresa adquirida"],c:0, e:"A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o:["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"],c:0, e:"Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso."}, {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o:["'Policy Decision Point (PDP) / Policy Engine'", "'Policy Enforcement Point (PEP) apenas'", "'Switch de camada 2 sem gerência'", "'Servidor de backup em fita magnética'"],c:0, e:"O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["'Microsegmentação da rede (Microsegmentation)'", "'Aumento da largura de banda do switch'", "'Uso de cabos blindados de par trançado'", "'Desativação de logs em roteadores'"],c:0, e:"A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["'Análise de risco contextual e 'viagem impossível' (Impossible Travel)'", "'Excesso de memória RAM utilizada no navegador'", "'Tempo de resposta do comando ping'", "'Número de caracteres da senha digitada'"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas."}, {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["'A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente'", "'O usuário deve redigitar sua senha manualmente a cada 60 segundos'", "'O tráfego de rede é reiniciado a cada hora para limpar o cache'", "'O computador é desligado automaticamente se ficar ocioso'"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois."}, {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso

crítico?", o: ["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"], c: 0, e: "Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id: "zt7", t: "secplus", d: "d2", q: "Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o: ["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"], c: 0, e: "Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id: "zt8", t: "secplus", d: "d2", q: "Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o: ["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"], c: 0, e: "ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id: "zt9", t: "secplus", d: "d2", q: "Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o: ["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"], c: 0, e: "Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id: "zt10", t: "secplus", d: "d2", q: "Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o: ["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"], c: 0, e: "Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id: "ctrl1", t: "secplus", d: "d2", q: "Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o: ["Preventive · Technical", "Detective · Technical", "Preventive · Managerial", "Deterrent · Technical"], c: 0, e: "Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."},

{id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o: ["Preventive", "Detective", "Deterrent", "Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective", "Corrective", "Preventive", "Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective", "Detective", "Compensating", "Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)", "Detective control do tipo technical", "Compensating control do tipo operational (dupla guarda)", "Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."}, {id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)", "Preventive · Physical (patrulha)", "Corrective · Operational", "Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial", "Preventive + Managerial", "Directive + Technical", "Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial)."}, {id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective", "Corrective — na categoria managerial (processo, documentação)", "Preventive", "Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial)."}, {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical", "Detective + Physical", "Preventive + Physical", "Deterrent + Technical"],c:1, e:"Detectores de movimento

e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective).", {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches)."}, // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade","Confidencialidade","Disponibilidade","Não-repúdio"],c:1, e:"Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação."}, {id:"cia2",t:"secplus",d:"d1",q:"Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticação"],c:1, e:"Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável."}, {id:"cia3",t:"secplus",d:"d1",q:"Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticidade"],c:2, e:"Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema."}, {id:"cia4",t:"secplus",d:"d3",q:"O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o:["Oferece integridade; NÃO dá confidencialidade (não cifra)","Oferece confidencialidade; NÃO dá integridade","Oferece disponibilidade; NÃO dá integridade","Oferece as 3 ao mesmo tempo"],c:0, e:"Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."}, {id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."}, {id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-

repúdio (non-repudiation) via assinatura digital", "Cluster de alta disponibilidade", "Hash MD5 da mensagem"], c:1, e: "Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id: "cia8", t: "secplus", d: "d3", q: "Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o: ["Disponibilidade — agiliza o backup", "Integridade — garante que o arquivo não corrompa", "Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras", "Autenticação — prova a identidade do usuário"], c:2, e: "Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id: "cia9", t: "secplus", d: "d1", q: "CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Não-repúdio"], c:1, e: "Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."}, {id: "cia10", t: "secplus", d: "d2", q: "CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Não-repúdio"], c:2, e: "Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id: "s101", t: "secplus", d: "d1", q: "Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o: ["BEC / CEO fraud (fraude do CEO)", "Whaling", "Vishing", "Tailgating"], c:0, e: "BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id: "s102", t: "secplus", d: "d1", q: "Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o: ["Spyware", "Ransomware", "Rootkit", "Worm"], c:1, e: "Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."}, {id: "s103", t: "secplus", d: "d1", q: "Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o: ["CVE pública", "Zero-day", "Backdoor", "Falso positivo"], c:1, e: "Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id: "s104", t: "secplus", d: "d1", q: "Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o: ["Ataque on-path (MITM)", "Negação de serviço", "SQL injection", "Força bruta"], c:0, e: "On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id: "s105", t: "secplus", d: "d1", q: "Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:

["Escassez", "Autoridade + urgência", "Prova social", "Reciprocidade"], c:1, e: "Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."},

{id:"s106", t:"secplus", d:"d1", q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco", "Validação de entrada (input)", "Backup", "Antivírus"], c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura =====

{id:"s201", t:"secplus", d:"d2", q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade", "Zero Trust", "Air gap", "Menor privilégio"], c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202", t:"secplus", d:"d2", q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio", "Separação de funções", "Rotação de cargo", "Need-to-know geográfico"], c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."},

{id:"s203", t:"secplus", d:"d2", q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz", "DMZ (screened subnet)", "VPN", "Intranet"], c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204", t:"secplus", d:"d2", q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust", "Defesa em profundidade", "Fail-open", "Segurança por obscuridade"], c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // =====

SECURITY+ D3 — Implementação ===== {id:"s301", t:"secplus", d:"d3", q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet", "SSH", "FTP", "HTTP"], c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."},

{id:"s302", t:"secplus", d:"d3", q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)", "Assimétrica (par de chaves)", "Hash de mão única", "Codificação Base64"], c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303", t:"secplus", d:"d3", q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta", "Algo que sabe, algo que tem, algo que é", "3 senhas diferentes", "Usuário, senha e e-mail"], c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."},

{id:"s304", t:"secplus", d:"d3", q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP", "Função hash (ex: SHA-256)", "Criptografia AES", "Assinatura Base64"], c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."},

{id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."}, {id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."}, {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) ===== {id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de

hardware", "Rootkit de firmware"], c:0, e: "Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque.", {id:"s108", t:"secplus", d:"d1", q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o: ["Firewall mal configurado", "Phishing + VPN sem MFA / credencial vazada", "Cabo de rede exposto", "Falta de antivírus"], c:1, e: "A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1.", {id:"s109", t:"secplus", d:"d1", q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o: ["Wireshark", "Mimikatz", "Nmap", "Nessus"], c:1, e: "Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110", t:"secplus", d:"d1", q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o: ["Escalada de privilégio (privilege escalation)", "Negação de serviço", "Engenharia social", "Sniffing"], c:0, e: "Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia.", {id:"s111", t:"secplus", d:"d4", q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o: ["Exfiltração", "Contenção", "Sanitização", "Ofuscação"], c:0, e: "Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão).", {id:"s112", t:"secplus", d:"d1", q:"Tripla extorsão' no ransomware combina:", o: ["Três vírus diferentes", "Criptografar + ameaçar vazamento de dados + chantagem os clientes da vítima", "Pedir resgate 3 vezes", "Atacar 3 empresas juntas"], c:1, e: "Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorquer também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais.", {id:"s113", t:"secplus", d:"d1", q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o: ["OWASP Top 10", "MITRE ATT&CK", "ISO 27001", "PCI-DSS"], c:1, e: "MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão.", {id:"s114", t:"secplus", d:"d4", q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o: ["SIEM", "SOAR", "EDR", "VPN"], c:1, e: "SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta.", {id:"s115", t:"secplus", d:"d3", q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o: ["EDR", "DLP", "IDS de rede", "Proxy"], c:0, e: "EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede.", {id:"s116", t:"secplus", d:"d3", q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o: ["DLP (Data Loss Prevention)", "SSO", "MFA", "VPN"], c:0, e: "DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum vazamento em si.", {id:"s117", t:"secplus", d:"d5", q:"O framework NIST CSF organiza a

segurança em 5 funções. Quais são?", o: ["Instalar, Atualizar, Testar, Auditar, Arquivar", "Identificar, Proteger, Detectar, Responder, Recuperar", "Planejar, Fazer, Checar, Agir, Revisar", "Prevenir, Punir, Prever, Provar, Publicar"], c: 1, e: "NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista.", {id: "s118", t: "secplus", d: "d5", q: "PEGADINHA: 'SOC 2' significa:", o: ["O time de analistas (Security Operations Center)", "Um relatório de auditoria dos controles de uma empresa", "Um tipo de firewall", "Uma fase da resposta a incidente"], c: 1, e: "SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes.", {id: "s119", t: "secplus", d: "d5", q: "HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o: ["Saúde (US) / Financeiro (US) / Pessoais (UE)", "Governo / Militar / Escolar", "Cartão / Senha / Biometria", "Nuvem / Rede / Endpoint"], c: 0, e: "HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id: "s120", t: "secplus", d: "d4", q: "A 'Cyber Kill Chain' descreve o quê?", o: ["As fases de um ataque, do reconhecimento à ação final", "Um tipo de criptografia", "Uma lei de proteção de dados", "Uma ferramenta de varredura"], c: 0, e: "Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id: "s121", t: "secplus", d: "d3", q: "Diferença entre IDS e IPS:", o: ["IDS detecta e alerta; IPS detecta e BLOQUEIA", "São a mesma coisa", "IDS é de disco; IPS é de rede", "IPS só grava log"], c: 0, e: "IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id: "s122", t: "secplus", d: "d3", q: "O que a PKI (infraestrutura de chave pública) sustenta na prática?", o: ["Certificados digitais (o cadeado do HTTPS)", "O antivírus", "O backup em nuvem", "A senha do Wi-Fi"], c: 0, e: "PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id: "s123", t: "secplus", d: "d3", q: "SAST e DAST testam segurança de software. A diferença:", o: ["SAST lê o código PARADO; DAST testa a app RODANDO", "SAST é pago; DAST é grátis", "São sinônimos", "SAST é de rede; DAST é de disco"], c: 0, e: "SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id: "s124", t: "secplus", d: "d5", q: "ISO/IEC 27001 é:", o: ["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)", "Uma lei dos EUA", "Um tipo de firewall", "Um scanner de vulnerabilidade"], c: 0, e: "ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id: "s125", t: "secplus", d: "d5", q: "TPRM (Third-Party Risk Management) trata de:", o: ["Avaliar o risco de segurança dos FORNECEDORES/terceiros", "Testar a própria rede", "Treinar funcionários", "Criptografar backup"], c: 0, e: "TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, //

===== SECURITY+ — lote extra (volume de simulado) =====

{id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

6. Durante uma Gap Analysis, a equipe de segurança descobre que uma política exige autenticação de dois fatores para todos os funcionários, mas o departamento comercial usa apenas usuário e senha há mais de um ano. Isso evidencia uma lacuna de:", o: ["Implementação e conformidade operacional (a política existe no papel, mas não é aplicada na prática)", "Falta de documentação gerencial", "Falha de hardware no servidor de banco de dados", "Incompatibilidade com leis trabalhistas"],c:0, e:"Uma das maiores causas de gap é a discrepância entre a política escrita (managerial) e a execução real pelos usuários (operational/technical)."}, {id:"gap7",t:"secplus",d:"d5",q:"Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser prioritariamente executada?", o:["Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções", "Apenas após um ataque cibernético de grandes proporções", "No encerramento definitivo das operações da empresa", "Exclusivamente antes de contratar estagiários"],c:0, e:"A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar."}, {id:"gap8",t:"secplus",d:"d5",q:"Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?", o:["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"],c:0, e:"Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado)."}, {id:"gap9",t:"secplus",d:"d5",q:"Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o:["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"],c:0, e:"A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o:["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"],c:0, e:"A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o:["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em

todos os computadores que possuem antivírus", "Bloqueie todo o tráfego da rede permanentemente"],c:0, e:"Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso.", {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o:["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"],c:0, e:"O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"],c:0, e:"A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede.", {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas.", {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois.", {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se

manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical", "Detective · Technical", "Preventive · Managerial", "Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o:["Preventive", "Detective", "Deterrent", "Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de

ontem. Este controle é:", o:["Detective","Corrective","Preventive","Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective).", {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective","Detective","Compensating","Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."}, {id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial)."}, {id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective","Corrective — na categoria managerial (processo, documentação)","Preventive","Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial)."}, {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical","Detective + Physical","Preventive + Physical","Deterrent + Technical"],c:1, e:"Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective)."}, {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um

controle primário (sistema operacional legado sem suporte a patches).", // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade","Confidencialidade","Disponibilidade","Não-repúdio"],c:1, e:"Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação."}, {id:"cia2",t:"secplus",d:"d1",q:"Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticação"],c:1, e:"Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável."}, {id:"cia3",t:"secplus",d:"d1",q:"Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticidade"],c:2, e:"Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema."}, {id:"cia4",t:"secplus",d:"d3",q:"O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o:["Oferece integridade; NÃO dá confidencialidade (não cifra)","Oferece confidencialidade; NÃO dá integridade","Oferece disponibilidade; NÃO dá integridade","Oferece as 3 ao mesmo tempo"],c:0, e:"Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."}, {id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."}, {id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-repúdio (non-repudiation) via assinatura digital","Cluster de alta disponibilidade","Hash MD5 da mensagem"],c:1, e:"Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id:"cia8",t:"secplus",d:"d3",q:"Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o:["Disponibilidade — agiliza o backup","Integridade — garante que o arquivo não corrompa","Confidencialidade — mesmo com vazamento do banco, invasores não leem as

senhas claras"; "Autenticação — prova a identidade do usuário"], c:2, e: "Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id: "cia9", t: "secplus", d: "d1", q: "CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Não-repúdio"], c:1, e: "Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."}, {id: "cia10", t: "secplus", d: "d2", q: "CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Não-repúdio"], c:2, e: "Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id: "s101", t: "secplus", d: "d1", q: "Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o: ["BEC / CEO fraud (fraude do CEO)", "Whaling", "Vishing", "Tailgating"], c:0, e: "BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id: "s102", t: "secplus", d: "d1", q: "Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o: ["Spyware", "Ransomware", "Rootkit", "Worm"], c:1, e: "Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."}, {id: "s103", t: "secplus", d: "d1", q: "Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o: ["CVE pública", "Zero-day", "Backdoor", "Falso positivo"], c:1, e: "Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id: "s104", t: "secplus", d: "d1", q: "Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o: ["Ataque on-path (MITM)", "Negação de serviço", "SQL injection", "Força bruta"], c:0, e: "On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id: "s105", t: "secplus", d: "d1", q: "Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o: ["Escassez", "Autoridade + urgência", "Prova social", "Reciprocidade"], c:1, e: "Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id: "s106", t: "secplus", d: "d1", q: "Injeção de comando SQL num campo de login explora principalmente a falta de:", o: ["Criptografia do disco", "Validação de entrada (input)", "Backup", "Antivírus"], c:1, e: "SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a

defesa."}, // ===== SECURITY+ D2 — Arquitetura =====

{id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação =====

{id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome,

DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."}, {id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."}, {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) ===== {id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO

é a defesa nº1.", {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o: ["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o: ["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vaziar dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorpe também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o: ["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de

auditoria dos controles de uma empresa", "Um tipo de firewall", "Uma fase da resposta a incidente"], c:1, e: "SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119", t:"secplus", d:"d5", q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)", "Governo / Militar / Escolar", "Cartão / Senha / Biometria", "Nuvem / Rede / Endpoint"], c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120", t:"secplus", d:"d4", q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final", "Um tipo de criptografia", "Uma lei de proteção de dados", "Uma ferramenta de varredura"], c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121", t:"secplus", d:"d3", q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA", "São a mesma coisa", "IDS é de disco; IPS é de rede", "IPS só grava log"], c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122", t:"secplus", d:"d3", q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)", "O antivírus", "O backup em nuvem", "A senha do Wi-Fi"], c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123", t:"secplus", d:"d3", q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO", "SAST é pago; DAST é grátis", "São sinônimos", "SAST é de rede; DAST é de disco"], c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124", t:"secplus", d:"d5", q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)", "Uma lei dos EUA", "Um tipo de firewall", "Um scanner de vulnerabilidade"], c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125", t:"secplus", d:"d5", q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros", "Testar a própria rede", "Treinar funcionários", "Criptografar backup"], c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) =====

- A)** DDoS
- B)** Phishing
- C)** SQL injection

D) Escalada de privilégio

7. Em que momento do ciclo de vida de implementação de um programa de segurança da informação a Gap Analysis deve ser prioritariamente executada?", o: ["Na fase inicial de planejamento e diagnóstico, antes de adquirir novas soluções", "Apenas após um ataque cibernético de grandes proporções", "No encerramento definitivo das operações da empresa", "Exclusivamente antes de contratar estagiários"], c:0, e: "A Gap Analysis é o passo zero do planejamento: ela estabelece o baseline e a linha de base sobre onde a empresa está versus onde ela precisa chegar."}, {id:"gap8",t:"secplus",d:"d5",q:"Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?", o: ["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"], c:0, e: "Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado)."}, {id:"gap9",t:"secplus",d:"d5",q:"Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o: ["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"], c:0, e: "A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o: ["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"], c:0, e: "A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o: ["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"], c:0, e: "Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso."}, {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o: ["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"], c:0, e: "O PDP (Policy

Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"],c:0, e:"A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas."}, {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois."}, {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota

moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o: ["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"], c: 0, e: "ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id: "zt9", t: "secplus", d: "d2", q: "Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o: ["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"], c: 0, e: "Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id: "zt10", t: "secplus", d: "d2", q: "Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o: ["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"], c: 0, e: "Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id: "ctrl1", t: "secplus", d: "d2", q: "Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o: ["Preventive · Technical", "Detective · Technical", "Preventive · Managerial", "Deterrent · Technical"], c: 0, e: "Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id: "ctrl2", t: "secplus", d: "d2", q: "A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o: ["Preventive", "Detective", "Deterrent", "Compensating"], c: 2, e: "O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id: "ctrl3", t: "secplus", d: "d4", q: "Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o: ["Detective", "Corrective", "Preventive", "Compensating"], c: 1, e: "A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id: "ctrl4", t: "secplus", d: "d2", q: "Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o: ["Corrective", "Detective", "Compensating", "Preventive"], c: 2, e: "Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."},

{id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."},

{id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial)."},

{id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective","Corrective — na categoria managerial (processo, documentação)","Preventive","Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial)."}, {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical","Detective + Physical","Preventive + Physical","Deterrent + Technical"],c:1, e:"Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective)."}, {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches)."}, // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o:["Integridade","Confidencialidade","Disponibilidade","Não-repúdio"],c:1, e:"Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação."}, {id:"cia2",t:"secplus",d:"d1",q:"Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original

não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticação"],c:1, e:"Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável."}, {id:"cia3",t:"secplus",d:"d1",q:"Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticidade"],c:2, e:"Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema."}, {id:"cia4",t:"secplus",d:"d3",q:"O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o:["Oferece integridade; NÃO dá confidencialidade (não cifra)","Oferece confidencialidade; NÃO dá integridade","Oferece disponibilidade; NÃO dá integridade","Oferece as 3 ao mesmo tempo"],c:0, e:"Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."}, {id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."}, {id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-repúdio (non-repudiation) via assinatura digital","Cluster de alta disponibilidade","Hash MD5 da mensagem"],c:1, e:"Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id:"cia8",t:"secplus",d:"d3",q:"Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o:["Disponibilidade — agiliza o backup","Integridade — garante que o arquivo não corrompa","Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras","Autenticação — prova a identidade do usuário"],c:2, e:"Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id:"cia9",t:"secplus",d:"d1",q:"CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:1, e:"Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."},

{id:"cia10",t:"secplus",d:"d2",q:"CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:2, e:"Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id:"s101",t:"secplus",d:"d1",q:"Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o:["BEC / CEO fraud (fraude do CEO)","Whaling","Vishing","Tailgating"],c:0, e:"BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id:"s102",t:"secplus",d:"d1",q:"Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o:["Spyware","Ransomware","Rootkit","Worm"],c:1, e:"Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."}, {id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o:["CVE pública","Zero-day","Backdoor","Falso positivo"],c:1, e:"Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura ===== {id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem

mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o:["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM

(Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC.", {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."}, {id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."}, {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) ===== {id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo

pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia.", {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o: ["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão).", {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vaziar dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorque também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais.", {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão.", {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o: ["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta.", {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede.", {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si.", {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista.", {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes.", {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoas (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."},

{id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

8. Qual indicador de maturidade é frequentemente empregado em relatórios de Gap Analysis para mensurar a evolução dos processos de segurança da organização?", o: ["CMMI (Capability Maturity Model Integration) com níveis de 1 a 5", "Tamanho do arquivo de log em Gigabytes", "Número de e-mails recebidos pela diretoria", "Velocidade de download da conexão de fibra"],c:0, e:"Modelos como CMMI avaliam o nível de maturidade dos processos de segurança (do nível 1: inicial/ad-hoc ao nível 5: otimizado)."}, {id:"gap9",t:"secplus",d:"d5",q:"Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o:["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"],c:0, e:"A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o:["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"],c:0, e:"A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o:["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"],c:0, e:"Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso."}, {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o:["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"],c:0, e:"O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"],c:0, e:"A

microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas."}, {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois."}, {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que

computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical", "Detective · Technical", "Preventive · Managerial", "Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o: ["Preventive", "Detective", "Deterrent", "Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective", "Corrective", "Preventive", "Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective", "Detective", "Compensating", "Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)", "Detective control do tipo technical", "Compensating control do tipo operational (dupla guarda)", "Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."},

{id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial)."}, {id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o:["Detective","Corrective — na categoria managerial (processo, documentação)","Preventive","Compensating"],c:1, e:"Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial)."}, {id:"ctrl9",t:"secplus",d:"d2",q:"O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o:["Detective + Technical","Detective + Physical","Preventive + Physical","Deterrent + Technical"],c:1, e:"Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective)."}, {id:"ctrl10",t:"secplus",d:"d2",q:"Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o:["Compensating control — uma alternativa porque o controle ideal não é possível","Corrective control — corrige o que já aconteceu","Preventive — barra o ataque antes","Deterrent — desanima o atacante"],c:0, e:"Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches)."}, // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id:"cia1",t:"secplus",d:"d1",q:"Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade","Confidencialidade","Disponibilidade","Não-repúdio"],c:1, e:"Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação."}, {id:"cia2",t:"secplus",d:"d1",q:"Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticação"],c:1, e:"Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável."}, {id:"cia3",t:"secplus",d:"d1",q:"Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade","Integridade","Disponibilidade","Autenticidade"],c:2,

e:"Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema.", {id:"cia4",t:"secplus",d:"d3",q:"O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o:["Oferece integridade; NÃO dá confidencialidade (não cifra)","Oferece confidencialidade; NÃO dá integridade","Oferece disponibilidade; NÃO dá integridade","Oferece as 3 ao mesmo tempo"],c:0, e:"Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo."}, {id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."}, {id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-repúdio (non-repudiation) via assinatura digital","Cluster de alta disponibilidade","Hash MD5 da mensagem"],c:1, e:"Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id:"cia8",t:"secplus",d:"d3",q:"Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o:["Disponibilidade — agiliza o backup","Integridade — garante que o arquivo não corrompa","Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras","Autenticação — prova a identidade do usuário"],c:2, e:"Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id:"cia9",t:"secplus",d:"d1",q:"CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:1, e:"Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."}, {id:"cia10",t:"secplus",d:"d2",q:"CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:2, e:"Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id:"s101",t:"secplus",d:"d1",q:"Um golpista manda e-mail SE

PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o: ["BEC / CEO fraud (fraude do CEO)", "Whaling", "Vishing", "Tailgating"], c: 0, e: "BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id: "s102", t: "secplus", d: "d1", q: "Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o: ["Spyware", "Ransomware", "Rootkit", "Worm"], c: 1, e: "Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."}, {id: "s103", t: "secplus", d: "d1", q: "Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o: ["CVE pública", "Zero-day", "Backdoor", "Falso positivo"], c: 1, e: "Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id: "s104", t: "secplus", d: "d1", q: "Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o: ["Ataque on-path (MITM)", "Negação de serviço", "SQL injection", "Força bruta"], c: 0, e: "On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id: "s105", t: "secplus", d: "d1", q: "Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o: ["Escassez", "Autoridade + urgência", "Prova social", "Reciprocidade"], c: 1, e: "Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id: "s106", t: "secplus", d: "d1", q: "Injeção de comando SQL num campo de login explora principalmente a falta de:", o: ["Criptografia do disco", "Validação de entrada (input)", "Backup", "Antivírus"], c: 1, e: "SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura ===== {id: "s201", t: "secplus", d: "d2", q: "O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o: ["Defesa em profundidade", "Zero Trust", "Air gap", "Menor privilégio"], c: 1, e: "Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id: "s202", t: "secplus", d: "d2", q: "Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o: ["Menor privilégio", "Separação de funções", "Rotação de cargo", "Need-to-know geográfico"], c: 0, e: "Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id: "s203", t: "secplus", d: "d2", q: "Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o: ["VLAN de voz", "DMZ (screened subnet)", "VPN", "Intranet"], c: 1, e: "DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id: "s204", t: "secplus", d: "d2", q: "Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o: ["Zero Trust", "Defesa

em profundidade", "Fail-open", "Segurança por obscuridade"], c:1, e: "Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger).", // =====

SECURITY+ D3 — Implementação ===== {id:"s301", t:"secplus", d:"d3", q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o: ["Telnet", "SSH", "FTP", "HTTP"], c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."},

{id:"s302", t:"secplus", d:"d3", q:"AES é um exemplo de criptografia:", o: ["Simétrica (mesma chave cifra e decifra)", "Assimétrica (par de chaves)", "Hash de mão única", "Codificação Base64"], c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303", t:"secplus", d:"d3", q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o: ["Senha, PIN e resposta secreta", "Algo que sabe, algo que tem, algo que é", "3 senhas diferentes", "Usuário, senha e e-mail"], c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."},

{id:"s304", t:"secplus", d:"d3", q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o: ["Compressão ZIP", "Função hash (ex: SHA-256)", "Criptografia AES", "Assinatura Base64"], c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."},

{id:"s305", t:"secplus", d:"d3", q:"Uma característica de HASH (diferente de criptografia) é que ele:", o: ["Pode ser revertido com a chave", "É de mão única (não reversível)", "Sempre encurta o texto pela metade", "Precisa de par de chaves"], c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306", t:"secplus", d:"d3", q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o: ["VPN (ex: IPsec/TLS)", "DNS", "DHCP", "SNMP"], c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // =====

SECURITY+ D4 — Operações/Resposta ===== {id:"s401", t:"secplus", d:"d4", q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação", "Preparação", "Recuperação", "Contenção"], c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."},

{id:"s402", t:"secplus", d:"d4", q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o: ["Firewall", "SIEM", "Proxy", "Antivírus"], c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403", t:"secplus", d:"d4", q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o: ["O HD / disco", "A memória RAM (dados voláteis)", "Os backups em fita", "Os logs impressos"], c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."},

{id:"s404", t:"secplus", d:"d4", q:"Depois de conter e erradicar um ataque, a fase que

documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC =====

{id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."},

{id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vazamento +

chantagear os clientes da vítima", "Pedir resgate 3 vezes", "Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorque também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o:["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava

log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

9. Um relatório de Gap Analysis identificou 45 lacunas de segurança. Como o CISO deve priorizar o plano de remediação perante o conselho executivo?", o:["Baseando-se no impacto de risco para o negócio, probabilidade de ocorrência e requisitos regulatórios mandatórios", "Remediando apenas as tarefas mais fáceis e rápidas primeiro", "Pelo custo mais alto das ferramentas disponíveis no mercado", "Em ordem alfabética do nome dos departamentos afetados"],c:0, e:"A priorização estratégica deve ser baseada em Gestão de Riscos (matriz de impacto x probabilidade) e conformidade legal estrita (compliance)."}, {id:"gap10",t:"secplus",d:"d5",q:"Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o:["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"],c:0, e:"A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id:"zt1",t:"secplus",d:"d2",q:"O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o:["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"],c:0, e:"Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso."}, {id:"zt2",t:"secplus",d:"d2",q:"Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o:["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"],c:0, e:"O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id:"zt3",t:"secplus",d:"d2",q:"Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o:["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"],c:0, e:"A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id:"zt4",t:"secplus",d:"d3",q:"Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o:["Análise de risco contextual

e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"],c:0, e:"Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas.", {id:"zt5",t:"secplus",d:"d2",q:"No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o:["A permissão e o token de acesso do usuário são reavaliados em tempo real a cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois.", {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as

regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) ===== {id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical","Detective · Technical","Preventive · Managerial","Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."}, {id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o: ["Preventive","Detective","Deterrent","Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective","Corrective","Preventive","Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective","Detective","Compensating","Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."}, {id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."}, {id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A

empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o: ["Directive + Managerial", "Preventive + Managerial", "Directive + Technical", "Corrective + Managerial"], c:1, e: "Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial).", {id: "ctrl8", t: "secplus", d: "d4", q: "Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?", o: ["Detective", "Corrective — na categoria managerial (processo, documentação)", "Preventive", "Compensating"], c:1, e: "Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial).", {id: "ctrl9", t: "secplus", d: "d2", q: "O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o: ["Detective + Technical", "Detective + Physical", "Preventive + Physical", "Deterrent + Technical"], c:1, e: "Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective).", {id: "ctrl10", t: "secplus", d: "d2", q: "Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o: ["Compensating control — uma alternativa porque o controle ideal não é possível", "Corrective control — corrige o que já aconteceu", "Preventive — barra o ataque antes", "Deterrent — desanima o atacante"], c:0, e: "Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches).", // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id: "cia1", t: "secplus", d: "d1", q: "Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade", "Confidencialidade", "Disponibilidade", "Não-repúdio"], c:1, e: "Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação.", {id: "cia2", t: "secplus", d: "d1", q: "Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Autenticação"], c:1, e: "Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável.", {id: "cia3", t: "secplus", d: "d1", q: "Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Autenticidade"], c:2, e: "Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema.", {id: "cia4", t: "secplus", d: "d3", q: "O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o: ["Oferece integridade; NÃO dá confidencialidade (não cifra)", "Oferece confidencialidade; NÃO dá integridade", "Oferece disponibilidade; NÃO dá integridade", "Oferece as 3 ao mesmo tempo"], c:0, e: "Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou

(integridade), mas não esconde nem cifra o conteúdo."},
{id:"cia5",t:"secplus",d:"d3",q:"Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o:["Hash SHA-256 puro","Criptografia AES simétrica","Assinatura digital com chave privada","Backup offline em fita"],c:2, e:"A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio."},
{id:"cia6",t:"secplus",d:"d3",q:"Dados confidenciais estão sendo transmitidos entre um usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o:["At rest — criptografia de disco BitLocker","In transit — túnel TLS / VPN IPsec","In use — enclaves seguros de CPU","Rest / transit / use — todas indistintas"],c:1, e:"Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN."}, {id:"cia7",t:"secplus",d:"d3",q:"Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o:["Criptografia AES","Não-repúdio (non-repudiation) via assinatura digital","Cluster de alta disponibilidade","Hash MD5 da mensagem"],c:1, e:"Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."},
{id:"cia8",t:"secplus",d:"d3",q:"Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o:["Disponibilidade — agiliza o backup","Integridade — garante que o arquivo não corrompa","Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras","Autenticação — prova a identidade do usuário"],c:2, e:"Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id:"cia9",t:"secplus",d:"d1",q:"CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:1, e:"Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."},
{id:"cia10",t:"secplus",d:"d2",q:"CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o:["Confidencialidade","Integridade","Disponibilidade","Não-repúdio"],c:2, e:"Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+
D1 — Ameaças ===== {id:"s101",t:"secplus",d:"d1",q:"Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o:["BEC / CEO fraud (fraude do CEO)","Whaling","Vishing","Tailgating"],c:0, e:"BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."},

{id:"s102",t:"secplus",d:"d1",q:"Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o:["Spyware","Ransomware","Rootkit","Worm"],c:1, e:"Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."},

{id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o:["CVE pública","Zero-day","Backdoor","Falso positivo"],c:1, e:"Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."},

{id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."},

{id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura =====

{id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."},

{id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação =====

{id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23),

FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."},
{id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."},
{id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."},
{id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."},
{id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."},
{id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O

número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder).", {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) ===== {id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vazador dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorque também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos

atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o: ["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."},

{id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o: ["SAST lê o código PARADO; DAST testa a app RODANDO", "SAST é pago; DAST é grátis", "São sinônimos", "SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)", "Uma lei dos EUA", "Um tipo de firewall", "Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros", "Testar a própria rede", "Treinar funcionários", "Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

10. Uma empresa adquire uma startup concorrente. Antes de conectar as duas redes corporativas, o time de segurança realiza uma Gap Analysis mútua. Qual o objetivo dessa medida de diligência prévia (Due Diligence)?", o: ["Identificar fragilidades de segurança da empresa adquirida que poderiam comprometer a rede compradora", "Reduzir o salário dos engenheiros da startup", "Instalar spyware para monitorar as conversas da equipe adquirida", "Apagar o histórico de e-mails da empresa adquirida"], c: 0, e: "A Gap Analysis em processos de fusões e aquisições (M&A due diligence) assegura que vulnerabilidades da rede adquirida não se tornem vetores de invasão lateral para a controladora."}, {id: "zt1", t: "secplus", d: "d2", q: "O modelo clássico de segurança de perímetro 'castelo e fosso' (onde tudo que está dentro da rede interna é confiável) foi superado pelo modelo Zero Trust. Qual é o lema e princípio operacional fundamental do Zero Trust?", o: ["'Nunca confie, sempre verifique' (Never trust, always verify)", "'Confie no perímetro interno e inspecione apenas a internet'", "'Confie em todos os computadores que possuem antivírus'", "'Bloqueie todo o tráfego da rede permanentemente'"], c: 0, e: "Zero Trust parte do pressuposto de que ameaças já existem dentro da rede. O princípio central é 'Never trust, always verify', exigindo validação explícita para cada acesso."}, {id: "zt2", t: "secplus", d: "d2", q: "Em uma arquitetura Zero Trust baseada no padrão NIST SP 800-207, qual componente avalia o contexto do usuário (saúde do dispositivo, localização, MFA) e decide conceder ou negar a sessão?", o: ["Policy Decision Point (PDP) / Policy Engine", "Policy Enforcement Point (PEP) apenas", "Switch de camada 2 sem gerência", "Servidor de backup em fita magnética"], c: 0, e: "O PDP (Policy Decision Point) analisa as políticas e telemetria para tomar a decisão de acesso, enquanto o PEP (Policy Enforcement Point) apenas executa a ordem (bloqueia ou libera o fluxo)."}, {id: "zt3", t: "secplus", d: "d2", q: "Qual técnica de rede é essencial no Zero Trust para impedir que um atacante que infectou uma estação de trabalho consiga se mover lateralmente para o servidor financeiro na mesma VLAN?", o: ["Microsegmentação da rede (Microsegmentation)", "Aumento da largura de banda do switch", "Uso de cabos blindados de par trançado", "Desativação de logs em roteadores"], c: 0, e: "A microsegmentação divide a rede em zonas de segurança granulares e isoladas, aplicando regras de firewall e inspeção pacote por pacote, mesmo entre máquinas na mesma sub-rede."}, {id: "zt4", t: "secplus", d: "d3", q: "Um colaborador em viagem de negócios acessa o portal corporativo com seu laptop da empresa. Minutos depois, uma tentativa de login com o mesmo usuário surge de um país a 10.000 km de distância. O sistema Zero Trust bloqueia imediatamente a segunda sessão com base em:", o: ["Análise de risco contextual e 'viagem impossível' (Impossible Travel)", "Excesso de memória RAM utilizada no navegador", "Tempo de resposta do comando ping", "Número de caracteres da senha digitada"], c: 0, e: "Acesso condicional em Zero Trust avalia atributos dinâmicos de contexto (como geolocalização e velocidade de deslocamento incompatível com as leis da física) para barrar invasores com senhas roubadas."}, {id: "zt5", t: "secplus", d: "d2", q: "No ecossistema Zero Trust, o que significa o conceito de Continuous Access Evaluation (CAE)?", o: ["A permissão e o token de acesso do usuário são reavaliados em tempo real a

cada evento crítico, podendo revogar a sessão instantaneamente", "O usuário deve redigitar sua senha manualmente a cada 60 segundos", "O tráfego de rede é reiniciado a cada hora para limpar o cache", "O computador é desligado automaticamente se ficar ocioso"],c:0, e:"CAE (Avaliação Contínua de Acesso) revoga sessões em segundos se um evento crítico acontecer (ex: senha alterada, dispositivo infectado), sem precisar esperar o token de acesso expirar horas depois.", {id:"zt6",t:"secplus",d:"d3",q:"Quais são os 3 pilares primordiais avaliados por uma arquitetura Zero Trust para autorizar o acesso a um recurso crítico?", o:["Identidade verificada, postura de saúde do dispositivo e contexto/ambiente da requisição", "Velocidade do processador, cor do gabinete e marca do roteador", "Horário de trabalho, tamanho do monitor e operadora de celular", "Sistema operacional exclusivo Linux, cabos de fibra e switches ópticos"],c:0, e:"Zero Trust correlaciona quem está pedindo (Identidade com MFA), por meio de que equipamento (Postura de conformidade do dispositivo / EDR) e em qual contexto (IP, local, risco)."}, {id:"zt7",t:"secplus",d:"d2",q:"Como o princípio do Menor Privilégio (Least Privilege) se manifesta na implementação de acesso em uma rede Zero Trust?", o:["O usuário recebe acesso 'Just-In-Time' (JIT) e 'Just-Enough-Access' (JEA) estritamente limitado ao recurso necessário pelo tempo da tarefa", "Todos os funcionários recebem privilégios de administrador para agilizar o suporte", "Ninguém na empresa pode acessar nenhum sistema sob hipótese alguma", "Apenas o departamento financeiro tem acesso a computadores"],c:0, e:"Zero Trust aplica privilégio mínimo dinâmico: o acesso não é permanente; é concedido apenas na hora necessária (JIT) e com os privilégios estritamente suficientes (JEA)."}, {id:"zt8",t:"secplus",d:"d2",q:"Qual solução de conectividade remota moderna substitui a VPN tradicional no modelo Zero Trust, permitindo acesso direto e seguro a aplicações específicas sem expor a rede corporativa inteira?", o:["ZTNA (Zero Trust Network Access)", "Telnet com autenticação simples", "RDP com porta padrão aberta no roteador", "VNC sem criptografia"],c:0, e:"ZTNA (Zero Trust Network Access) concede acesso granular por aplicação (app-to-user) em vez de dar acesso completo à camada de rede (como faz a VPN legada), isolando a infraestrutura corporativa."}, {id:"zt9",t:"secplus",d:"d2",q:"Uma empresa implementa Zero Trust e exige que computadores pessoais (BYOD) não possam acessar dados confidenciais a menos que estejam com o sistema operacional atualizado, disco criptografado e antivírus ativo. Essa checagem é conhecida como:", o:["Verificação de Postura de Segurança do Dispositivo (Device Posture Check / Health Attestation)", "Autenticação por chave assimétrica reversa", "Filtro de pacotes estático no roteador", "Inspeção de cabeçalho TCP em lote"],c:0, e:"Device Posture Assessment garante que apenas dispositivos em conformidade com as regras de segurança corporativas possam se conectar a aplicações críticas."}, {id:"zt10",t:"secplus",d:"d2",q:"Por que o Zero Trust NÃO pode ser adquirido como um 'produto de prateleira' ou uma caixa de appliance único?", o:["Porque Zero Trust é um modelo arquitetural e filosófico abrangente que envolve integração de IAM, endpoints, redes, dados e aplicações", "Porque a tecnologia é proibida por leis federais", "Porque só funciona em computadores quânticos", "Porque é restrito a empresas de defesa aeroespacial"],c:0, e:"Zero Trust não é um software único nem um firewall específico: é uma

estratégia de arquitetura que integra identidades, dispositivos, infraestrutura e dados de forma contínua."}, // ===== AULA 1.1 — SECURITY CONTROLS (Messer SY0-701) =====

{id:"ctrl1",t:"secplus",d:"d2",q:"Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?", o:["Preventive · Technical","Detective · Technical","Preventive · Managerial","Deterrent · Technical"],c:0, e:"Firewall é ferramenta tecnológica (Technical); a regra barra o pacote antes de entrar na rede (Preventive)."},

{id:"ctrl2",t:"secplus",d:"d2",q:"A empresa instala placas na entrada dizendo 'esta área está sendo gravada por câmeras de segurança'. Nenhum dispositivo físico novo foi adicionado. Qual é o propósito primordial deste controle?", o:

["Preventive","Detective","Deterrent","Compensating"],c:2, e:"O aviso desanima e desencoraja a ação maliciosa (Deterrent), mas não impede fisicamente a entrada nem grava nada por si só."}, {id:"ctrl3",t:"secplus",d:"d4",q:"Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:", o:["Detective","Corrective","Preventive","Compensating"],c:1, e:"A restauração do backup ocorre DEPOIS do incidente para restaurar o estado operacional do sistema (Corrective)."}, {id:"ctrl4",t:"secplus",d:"d2",q:"Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?", o:["Corrective","Detective","Compensating","Preventive"],c:2, e:"Compensating control: é uma contramedida alternativa temporária aplicada quando o controle principal/ideal (o patch do fabricante) é inviável no momento."},

{id:"ctrl5",t:"secplus",d:"d5",q:"A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:", o:["Preventive control do tipo managerial (separation of duties)","Detective control do tipo technical","Compensating control do tipo operational (dupla guarda)","Directive control do tipo physical"],c:0, e:"Separação de funções (separation of duties) é uma política administrativa/gerencial (Managerial) que previne fraudes e erros impedindo a ação unilateral (Preventive)."},

{id:"ctrl6",t:"secplus",d:"d4",q:"Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta imediatamente. Este controle é:", o:["Detective · Operational (patrulha)","Preventive · Physical (patrulha)","Corrective · Operational","Detective · Technical"],c:0, e:"A patrulha de segurança faz parte dos procedimentos operacionais humanos (Operational) e atua identificando anomalias durante a inspeção (Detective)."}, {id:"ctrl7",t:"secplus",d:"d5",q:"A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?", o:["Directive + Managerial","Preventive + Managerial","Directive + Technical","Corrective + Managerial"],c:1, e:"Política de segurança orienta e evita o erro (Preventive) via processo administrativo e diretriz organizacional (Managerial)."},

{id:"ctrl8",t:"secplus",d:"d4",q:"Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o

playbook. Qual controle é este?", o: ["Detective", "Corrective — na categoria managerial (processo, documentação)", "Preventive", "Compensating"], c: 1, e: "Lições aprendidas e atualização de políticas após incidente é um controle corretivo (Corrective) no nível gerencial/processual (Managerial).", {id: "ctrl9", t: "secplus", d: "d2", q: "O datacenter instalou detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:", o: ["Detective + Technical", "Detective + Physical", "Preventive + Physical", "Deterrent + Technical"], c: 1, e: "Detectores de movimento e sensores volumétricos são dispositivos físicos (Physical) cuja função é detectar intrusões e emitir alertas (Detective).", {id: "ctrl10", t: "secplus", d: "d2", q: "Depois de um incidente, o time de segurança adiciona um módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:", o: ["Compensating control — uma alternativa porque o controle ideal não é possível", "Corrective control — corrige o que já aconteceu", "Preventive — barra o ataque antes", "Deterrent — desanima o atacante"], c: 0, e: "Compensating: uso de outros meios para compensar a ausência de um controle primário (sistema operacional legado sem suporte a patches).", // ===== AULA 1.2 — THE CIA TRIAD (Messer SY0-701) ===== {id: "cia1", t: "secplus", d: "d1", q: "Um atacante intercepta e Lê uma comunicação confidencial entre dois sistemas sem autorização. Que objetivo da tríade CIA foi diretamente comprometido?", o: ["Integridade", "Confidencialidade", "Disponibilidade", "Não-repúdio"], c: 1, e: "Confidencialidade ('só quem pode, vê'): a leitura indevida por terceiro quebra o sigilo da informação.", {id: "cia2", t: "secplus", d: "d1", q: "Um atacante INJETA código numa mensagem enviada a um banco, fazendo o banco executar uma transferência que o usuário original não ordenou. Que objetivo da tríade foi comprometido?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Autenticação"], c: 1, e: "Integridade: o dado foi adulterado no trajeto, deixando de ser exato e confiável.", {id: "cia3", t: "secplus", d: "d1", q: "Um servidor web de e-commerce fica completamente inacessível devido a um ataque de negação de serviço distribuído (DDoS). Que objetivo da tríade CIA foi comprometido?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Autenticidade"], c: 2, e: "Disponibilidade: o serviço caiu e os clientes legítimos não conseguem acessar o sistema.", {id: "cia4", t: "secplus", d: "d3", q: "O que uma função HASH criptográfica (como SHA-256) oferece e o que ela NÃO oferece?", o: ["Oferece integridade; NÃO dá confidencialidade (não cifra)", "Oferece confidencialidade; NÃO dá integridade", "Oferece disponibilidade; NÃO dá integridade", "Oferece as 3 ao mesmo tempo"], c: 0, e: "Hash é unidirecional: gera uma impressão digital única para checar se o dado mudou (integridade), mas não esconde nem cifra o conteúdo.", {id: "cia5", t: "secplus", d: "d3", q: "Qual controle criptográfico oferece simultaneamente: integridade do dado + autenticação do autor + não-repúdio (non-repudiation)?", o: ["Hash SHA-256 puro", "Criptografia AES simétrica", "Assinatura digital com chave privada", "Backup offline em fita"], c: 2, e: "A assinatura digital cifra o hash com a chave privada do remetente, garantindo integridade + autenticidade + não-repúdio.", {id: "cia6", t: "secplus", d: "d3", q: "Dados confidenciais estão sendo transmitidos entre um

usuário remoto e o servidor corporativo pela internet. Qual estado do dado e proteção correspondente?", o: ["At rest — criptografia de disco BitLocker", "In transit — túnel TLS / VPN IPsec", "In use — enclaves seguros de CPU", "Rest / transit / use — todas indistintas"], c:1, e: "Dado em trânsito (in transit) trafega pela rede e deve ser protegido com TLS ou VPN.", {id: "cia7", t: "secplus", d: "d3", q: "Uma empresa financeira precisa garantir perante auditoria judicial que um gerente não possa negar ter autorizado uma transferência bancária. Qual garantia técnica é exigida?", o: ["Criptografia AES", "Não-repúdio (non-repudiation) via assinatura digital", "Cluster de alta disponibilidade", "Hash MD5 da mensagem"], c:1, e: "Não-repúdio: impede que o autor negue a autoria da transação, pois apenas a sua chave privada exclusiva pôde gerar a assinatura."}, {id: "cia8", t: "secplus", d: "d3", q: "Uma aplicação web armazena senhas no banco de dados utilizando hash com salt (ex: bcrypt). Qual objetivo primordial da tríade isso protege e por quê?", o: ["Disponibilidade — agiliza o backup", "Integridade — garante que o arquivo não corrompa", "Confidencialidade — mesmo com vazamento do banco, invasores não leem as senhas claras", "Autenticação — prova a identidade do usuário"], c:2, e: "Confidencialidade: o hash com salt garante que o segredo (a senha) não seja revelado mesmo se a tabela for roubada."}, {id: "cia9", t: "secplus", d: "d1", q: "CENÁRIO: Durante uma rotina de manutenção noturna, um script em lote com erro de lógica altera indevidamente os campos de limite de crédito de 10.000 clientes, sem dolo ou ataque externo. Qual pilar da tríade CIA foi diretamente violado?", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Não-repúdio"], c:1, e: "Integridade: a modificação incorreta dos dados contábeis corrompeu a exatidão e a integridade da base, independentemente de ter havido dolo."}, {id: "cia10", t: "secplus", d: "d2", q: "CENÁRIO: Um hospital implementa servidores de prontuário eletrônico com fontes de alimentação redundantes, gerador a diesel, replicação multi-site síncrona e balanceamento de carga automático. Essa arquitetura foi desenhada para priorizar:", o: ["Confidencialidade", "Integridade", "Disponibilidade", "Não-repúdio"], c:2, e: "Disponibilidade: no-breaks, geradores, replicação e redundância existem para assegurar que os médicos acessem os prontuários 24/7 sem interrupções."}, // ===== SECURITY+ D1 — Ameaças ===== {id: "s101", t: "secplus", d: "d1", q: "Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o: ["BEC / CEO fraud (fraude do CEO)", "Whaling", "Vishing", "Tailgating"], c:0, e: "BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta."}, {id: "s102", t: "secplus", d: "d1", q: "Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o: ["Spyware", "Ransomware", "Rootkit", "Worm"], c:1, e: "Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede."}, {id: "s103", t: "secplus", d: "d1", q: "Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o: ["CVE pública", "Zero-day", "Backdoor", "Falso positivo"], c:1, e: "Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias'

pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o:["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressão desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura ===== {id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo

que sabe, algo que tem, algo que é", "3 senhas diferentes", "Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."}, {id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."}, {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético

pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele.", // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vaziar dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorque também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o:["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de

rede", "Proxy"], c:0, e: "EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede.", {id:"s116", t:"secplus", d:"d3", q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)", "SSO", "MFA", "VPN"], c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si.", {id:"s117", t:"secplus", d:"d5", q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar", "Identificar, Proteger, Detectar, Responder, Recuperar", "Planejar, Fazer, Checar, Agir, Revisar", "Prevenir, Punir, Prever, Provar, Publicar"], c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista.", {id:"s118", t:"secplus", d:"d5", q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)", "Um relatório de auditoria dos controles de uma empresa", "Um tipo de firewall", "Uma fase da resposta a incidente"], c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes.", {id:"s119", t:"secplus", d:"d5", q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)", "Governo / Militar / Escolar", "Cartão / Senha / Biometria", "Nuvem / Rede / Endpoint"], c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC.", {id:"s120", t:"secplus", d:"d4", q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final", "Um tipo de criptografia", "Uma lei de proteção de dados", "Uma ferramenta de varredura"], c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo.", {id:"s121", t:"secplus", d:"d3", q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA", "São a mesma coisa", "IDS é de disco; IPS é de rede", "IPS só grava log"], c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção.", {id:"s122", t:"secplus", d:"d3", q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)", "O antivírus", "O backup em nuvem", "A senha do Wi-Fi"], c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital.", {id:"s123", t:"secplus", d:"d3", q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO", "SAST é pago; DAST é grátis", "São sinônimos", "SAST é de rede; DAST é de disco"], c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps.", {id:"s124", t:"secplus", d:"d5", q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)", "Uma lei dos EUA", "Um tipo de firewall", "Um scanner

de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR).", {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A) DDoS
- B) Phishing
- C) SQL injection
- D) Escalada de privilégio

GABARITO COMENTADO

- 1) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 2) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 3) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 4) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 5) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 6) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 7) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 8) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 9) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 10) **A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.

